

DATA ENCRYPTION POLICY

Revision: 1.0

Issue Status: A

Prepared by	Designation
Kalpana J	Project Manager
Approved by	Designation
Gayathri V	Chief Information Security Officer

This document is the property of and proprietary to Ideas2IT. Contents of this document should not be disclosed to any unauthorized person. This document may not, in whole or in part, be reduced, reproduced, stored in a retrieval system, translated, or transmitted in any form or by any means, electronic or mechanical.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/DEP
		Date	13/03/2024
		Revision No	1.0
		Page	1 of 7

Data Encryption and Decryption Policy

1. Purpose

The purpose of this Data Encryption and Decryption Policy is to establish guidelines for the encryption and decryption of sensitive data within Ideas2IT. This policy ensures the confidentiality, integrity, and security of organizational data in compliance with relevant laws, industry standards, and best practices.

2. Scope

This policy applies to all employees, contractors, third-party vendors, and other stakeholders who have access to the organization's systems, networks, and data. It covers:

- Data at rest (e.g., files stored on servers, databases, cloud storage)
- Data in transit (e.g., data being transmitted over networks, APIs)
- Data processed by or stored on user devices (e.g., laptops, mobile devices)

3. Definitions

- **Encryption:** The process of converting data into a code to prevent unauthorized access.
- **Decryption:** The process of converting encrypted data back into its original form.
- **Sensitive Data:** Data that, if disclosed, could harm the organization or individuals, including but not limited to:
 - Personally Identifiable Information (PII)
 - Financial data
 - Intellectual property
 - Health data

 Let's Innovate	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/DEP
		Date	13/03/2024
		Revision No	1.0
		Page	2 of 7

- Passwords
- Confidential business information

4. Data Classification and Encryption Requirements

The organization classifies data based on sensitivity and applies different encryption levels accordingly:

- **High-Sensitivity Data:** Includes sensitive personal data, financial data, and proprietary information. This data must be encrypted both **at rest** and **in transit**.
- **Medium-Sensitivity Data:** Includes project-related information, internal communications, etc. This data must be encrypted during transmission (in transit) and may be encrypted at rest based on the business needs.
- **Low-Sensitivity Data:** General information that is not sensitive and does not require encryption at rest but should be encrypted during transmission if applicable.

5. Encryption Standards and Protocols

The organization will adhere to the following standards and protocols for encryption:

- **Encryption Algorithms:**
 - **AES-256** (Advanced Encryption Standard) for data encryption at rest.
 - **RSA-2048** or **RSA-4096** for public key encryption for transmitting data securely.
 - **TLS 1.2** or higher for encrypting data in transit over networks.
 - **ECC (Elliptic Curve Cryptography)** may also be used for specific use cases such as mobile or IoT devices, where applicable.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/DEP
		Date	13/03/2024
		Revision No	1.0
		Page	3 of 7

- **Encryption Key Management:**

- All encryption keys should be stored securely using **Hardware Security Modules (HSM)** or **Key Management Systems (KMS)**.
- Keys must be rotated periodically, and a clear process for key deactivation, revocation, and destruction must be in place.
- Multi-factor authentication (MFA) should be required for accessing encryption keys.

- **Data Masking and Tokenization:**

- For certain use cases, sensitive data may be protected using **data masking** or **tokenization** techniques in non-production environments, where encryption is not required.

6. Roles and Responsibilities

- **Chief Information Security Officer (CISO):**

- Ensures compliance with the encryption and decryption policy.
- Oversees the implementation of encryption technologies across the organization.
- Reports to senior management on the encryption status and any issues regarding data protection.

- **IT Security Team:**

- Implements and maintains encryption solutions.
- Manages the lifecycle of encryption keys (generation, distribution, storage, rotation, and revocation).
- Monitors and audits encrypted data to ensure compliance with the policy.

- **End Users:**

- End users are responsible for using encryption tools provided by the organization when handling sensitive data.
- Ensure that passwords, tokens, or other credentials used for data encryption are kept confidential and are not shared with unauthorized individuals.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/DEP
		Date	13/03/2024
		Revision No	1.0
		Page	4 of 7

7. Data Encryption at Rest

- All sensitive data stored on physical devices, databases, and cloud environments must be encrypted using **AES-256** encryption.
- Backup data containing sensitive information should also be encrypted to prevent unauthorized access.
- File systems, storage devices, and databases storing encrypted data should have access controls in place to prevent unauthorized decryption.

8. Data Encryption in Transit

- All sensitive data transmitted over networks, including email, APIs, and web services, must be encrypted using **TLS 1.2 or higher**.
- When sending sensitive information over email, end-to-end encryption should be implemented, if feasible, or an encrypted file should be used (e.g., encrypted ZIP files).
- VPNs (Virtual Private Networks) and secure tunnels should be used for remote access to internal systems.

9. Key Management

- **Key Generation:** Encryption keys should be generated using secure, random methods. Symmetric keys (e.g., AES keys) and asymmetric keys (e.g., RSA keys) must be generated with industry-standard practices.
- **Key Storage:** Keys must be stored in a secure manner, such as in a **Hardware Security Module (HSM)**, **Key Management System (KMS)**, or similar secure systems.
- **Key Rotation:** Encryption keys should be rotated at regular intervals and whenever there is any indication of compromise. Key rotation processes must be automated, where possible.
- **Key Revocation and Destruction:** Encryption keys should be revoked and securely destroyed when no longer required or when a security breach is suspected.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/DEP
		Date	13/03/2024
		Revision No	1.0
		Page	5 of 7

10. Access Control and Auditing

- Access to encrypted data should be restricted to authorized personnel only. Access controls must be in place based on the principle of **least privilege**.
- Audit logs should be maintained for all encryption and decryption activities. Logs should include information about who accessed encrypted data, when, and the action taken (e.g., encryption, decryption).
- Audit logs must be reviewed regularly by security teams to detect any unauthorized access attempts.

11. Compliance with Legal and Regulatory Requirements

- The organization must comply with applicable laws and regulations related to data protection and encryption, including but not limited to:
 - **The Information Technology Act, 2000** and the **Reasonable Security Practices Rules** under it.
 - **General Data Protection Regulation (GDPR)** (if dealing with data from EU residents).
 - **The Personal Data Protection Bill, 2019** (India-specific regulation).
 - Industry-specific encryption requirements (e.g., for healthcare or finance sectors).

12. Encryption for Mobile and Remote Devices

- Mobile devices (smartphones, laptops) used by employees must use full disk encryption to protect sensitive data stored on the device.
- **Mobile Device Management (MDM)** tools should be used to enforce encryption and prevent unauthorized access to encrypted data.

 Let's Innovate	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/DEP
		Date	13/03/2024
		Revision No	1.0
		Page	6 of 7

- Encryption protocols for remote access should be configured to ensure secure access to the company's internal systems over public or untrusted networks.

13. Training and Awareness

- Employees should be regularly trained on data encryption principles, how to handle sensitive data, and the tools and procedures for encryption and decryption.
- Specific training should be provided for roles involved in managing encryption keys and access controls.

14. Policy Enforcement and Violations

- Violation of the encryption policy can result in disciplinary action, including termination of employment or contracts, as per the company's policies.
- The organization reserves the right to audit and review systems to ensure compliance with this policy.

15. Review and Updates

This policy will be reviewed periodically and updated as necessary to reflect changes in the organization's data security requirements, technological advancements, or legal/regulatory updates.

Conclusion

This Data Encryption and Decryption Policy aims to protect sensitive organizational and client data from unauthorized access, ensuring confidentiality and integrity. The policy sets clear standards for encryption practices, key management, compliance, and roles, contributing to a robust information security framework.